安全自评报告

保额罗盘 InsureCompass

01 范围、资产与权限

评估对象为本项目浏览器页面、Node静态服务与AI代理处理器。评估方式为代码检查、34项自动测试、浏览器验收及DeepSeek真实接口联调；不代替独立安全审计。

资产	保护目标	边界
模型API凭据	不进入前端或源码包	仅服务端环境/内存使用
家庭财务输入	最小收集、避免非必要外传	默认本地计算，授权后摘要送模型
对话与模型回答	不被当作可信执行指令	文本渲染，不执行模型工具或代码
配置和源码	访客不可修改或读取服务端源码	静态根目录限制为dist

权限分级实现说明

访客拥有测算、打印和提问能力；服务进程拥有使用凭据调用上游模型的能力；部署维护者通过主机或托管平台管理配置与版本。当前未实现应用内账号、管理员后台或基于用户角色的RBAC，不将平台权限假称为应用内功能。

权限验证

访问 /.env.server 和 /server/index.mjs 均返回404；接口状态仅返回配置状态、模型名和说明，不返回密钥。实际应用的主机/平台协作者权限需要部署维护者另行配置。

02 已实现控制与验证证据

控制	实现与证据	结果
密钥边界	仅服务端读取；浏览器调用同源/api/chat；配置文件被Git忽略	已实现
来源约束	精确Origin白名单；拒绝不在列表中的来源和无来源POST	已测试
输入约束	JSON类型、16KiB正文、消息数量/角色/长度、上下文长度	已测试
资源约束	每实例30次/分钟，最多2并发；20秒上游超时	已测试
错误脱敏	上游错误正文和内部异常不直接返回前端	已测试
浏览器防护	CSP、X-Frame-Options、nosniff、Referrer-Policy	已检查
授权与持久化	摘要同步默认关闭；无应用数据库和持久化聊天记录	已检查
供应链	移除未引用的平台依赖与模板，保留锁文件；npm审计0项已知漏洞	已检查

AI安全措施

系统提示限定为保障教育，要求只解释计算器提供的金额，不推荐具体商业产品或承诺核保。客户端不能提交system角色；财务摘要以普通数据消息传入。回答按纯文本呈现，模型无文件、命令或外部工具执行权限。

证据位置：tests/chat-handler.test.mjs、tests/calculator.test.mjs、tests/ai-service.test.mjs；server/chat-handler.ts、server/index.mjs；docs/TESTING.md。

03 已知风险清单

风险 / 级别	剩余风险	后续处理
公网滥用 / 高	无用户身份鉴权，Origin可由非浏览器伪造	网关防护、账号预算、用户级配额
分布式限流 / 中	限制仅在单实例内存生效，重启归零	使用共享存储统一计数和熔断
模型错误与注入 / 中	提示约束不能保证回答正确或不偏离	扩充对抗样例，保留公式核对入口
第三方数据政策 / 中	授权内容送往模型服务，留存范围由服务商决定	部署方核实政策、最小化摘要
公网部署配置 / 中	HTTPS、证书、反向代理和托管权限取决于部署	上线检查及最小协作者权限
参数与模型局限 / 中	没有保费、通胀、贴现或精算风险估计	明确适用范围并验证新增模型
依赖维护 / 低	漏洞扫描无法覆盖未知问题；图表库为既有版本	定期审计与兼容性升级
性能与打印差异 / 低	脚本较大；浏览器字体和纸张设置可能影响打印	按需加载和更多终端复核

本次未实施范围

未开展独立渗透测试、跨地区或多实例压力测试，不宣称达到任何未经过认证的安全等级。未配置应用数据库，因此没有数据库行级权限或用户数据隔离功能可供宣称。

04 自评结论与上线检查

自评结论

本版本已实现服务端凭据隔离、默认关闭财务同步、输入与接口约束、错误脱敏和基本资源保护，并通过功能与真实接口联调验证。可作为家庭保障教育和竞赛原型交付。公网长期运营前仍需强化滥用防护、统一配额和部署侧权限。

上线检查项	责任方
使用HTTPS，核对实际域名及AI_ALLOWED_ORIGINS	部署维护者
把模型密钥放在秘密变量管理中，限制协作者	部署维护者
设置模型账号费用预算、告警与撤销流程	部署维护者
验证未登录访问、真实问答和密钥无前端暴露	项目维护者
复核第三方隐私政策及用户授权说明	项目维护者
对齐演示版本、PDF、源码包和测试记录	项目维护者

凭据与异常处理

密钥轮换通过服务端环境更新并重启/重新部署完成；发现异常用量时可禁用模型凭据，计算器仍独立工作。应用不记录原始对话与上游错误正文；主机和反向代理日志应按最小化原则配置。

报告日期：2026-10-28。自评所称“已实现”指当前代码与本次验证范围，“后续处理”不计入已完成功能。